

ToysRus Controls and Compliance Audit

Prepared For: *internal stakeholder*

Date: *8 / 9 / 2026*

Prepared By: *Magdy Muhammad Mansour (Security Analyst)*

Executive Summary:

Purpose: to systematically evaluate an organization's security controls, policies, and infrastructure to identify vulnerabilities before attackers can exploit them.

Top Risks:

- 1- *Currently, all employees have access to customer data, which is a major confidentiality violation.*
- 2- *There are no disaster recovery plans in place. This could affect business continuity in case of a breach.*
- 3- *Credit card information is not encrypted and all employees currently have access to internal data, including customers' credit card information*

Business Impact:

Neglecting to address these security vulnerabilities may result in regulatory fines for GDPR non-compliance along with severe financial loss from data compromise.

Audit Scope & Objectives:

Scope: This audit covers ToysRus' digital infrastructure, physical store assets, and adherence to PCI DSS and GDPR regulatory frameworks.

Objectives: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices that need to be implemented to improve ToysRus' security posture and provide actionable recommendations for risk mitigation.

Audit Methodology:

This audit followed a comprehensive, multi-phase approach to evaluate ToysRus' security posture and compliance readiness:

- 1. **Documentation Review:** Review of existing security policies, asset inventories, and compliance frameworks.
- 2. **Stakeholder Interviews:** Discussions with key personnel to understand operational workflows, access control practices, and existing risk management strategies.
- 3. **Physical and Logical Assessment:** Evaluation of physical security measures (locks, CCTV) and logical security configurations (firewall rules, legacy system access).
- 4. **Gap Analysis:** Comparing existing controls against industry best practices (PCI DSS, GDPR, SOC 2) to identify vulnerabilities.

Controls assessment checklist

Yes	No	Control	Explanation
☐	☒	Least Privilege	Currently, all employees have access to customer data; privileges need to be limited to reduce the risk of a breach.
☐	☒	Disaster recovery plans	There are no disaster recovery plans in place. These need to be implemented to ensure business continuity.
☐	☒	Password policies	Employee password requirements are minimal, which could allow a threat actor to more easily access secure data/other assets via employee work equipment/the internal network.
☐	☒	Separation of duties	Needs to be implemented to reduce the possibility of fraud/access to critical data,

since the company CEO currently runs day-to-day operations and manages the payroll.

☒ ☐ Firewall

The existing firewall blocks traffic based on an appropriately defined set of security rules.

☐ ☒ Intrusion detection system (IDS)

The IT department needs an IDS in place to help identify possible intrusions by threat actors.

☐ ☒ Backups

The IT department needs to have backups of critical data, in the case of a breach, to ensure business continuity.

☒ ☐ Antivirus software

Antivirus software is installed and monitored regularly by the IT department.

☐ ☒ Manual monitoring, maintenance, and intervention for legacy systems

The list of assets notes the use of legacy systems. The risk assessment indicates that these systems are monitored and maintained, but there is not a regular schedule in place for this task and procedures/policies related to intervention are unclear, which could place these systems at risk of a breach.

☐ ☒ Encryption

Encryption is not currently used; implementing it would provide greater confidentiality of sensitive information.

☐	☒	Password management system	<i>There is no password management system currently in place; implementing this control would improve IT department/other employee productivity in the case of password issues.</i>
☒	☐	Locks (offices, storefront, warehouse)	<i>The store's physical location, which includes the company's main offices, store front, and warehouse of products, has sufficient locks.</i>
☒	☐	Closed-circuit television (CCTV) surveillance	<i>CCTV is installed/functioning at the store's physical location.</i>
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)	<i>ToysRus' physical location has a functioning fire detection and prevention system.</i>

Compliance checklist:

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
☐	☒	Only authorized users have access to customers' credit card information.	<i>Currently, all employees have access to the company's internal data.</i>
☐	☒	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.	<i>Credit card information is not encrypted and all employees currently have access to internal data, including customers' credit card information.</i>

☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	<i>The company does not currently use encryption to better ensure the confidentiality of customers' financial information.</i>
☐	☒	Adopt secure password management policies.	<i>Password policies are nominal and no password management system is currently in place.</i>

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
☐	☒	E.U. customers' data is kept private/secured.	<i>The company does not currently use encryption to better ensure the confidentiality of customers' financial information.</i>
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	<i>There is a plan to notify E.U. customers within 72 hours of a data breach.</i>
☐	☒	Ensure data is properly classified and inventoried.	<i>Current assets have been inventoried/listed, but not classified.</i>
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.	<i>Privacy policies, procedures, and processes have been developed and enforced among IT team members and other employees, as needed.</i>

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
☐	☒	User access policies are established.	<i>Controls of Least Privilege and separation of duties are not currently in place; all employees have access to internally stored data.</i>
☐	☒	Sensitive data (PII/SPII) is confidential/private.	<i>Encryption is not currently used to better ensure the confidentiality of PII/SPII.</i>
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.	<i>Data integrity is in place.</i>
☐	☒	Data is available to individuals authorized to access it.	<i>While data is available to all employees, authorization needs to be limited to only the individuals who need access to it to do their jobs.</i>

Recommendations:

Multiple controls need to be implemented to improve ToysRus' security posture and better ensure the confidentiality of sensitive information, including: Least Privilege, disaster recovery plans, password policies, separation of duties, an IDS, ongoing legacy system management, encryption, and a password management system.

To address gaps in compliance, ToysRus needs to implement controls such as Least Privilege, separation of duties, and encryption. The company also needs to properly classify assets, to identify additional controls that may need to be implemented to improve their security posture and better protect sensitive information.

Stakeholder Roles & Responsibilities

To successfully implement the recommended controls and ensure ongoing compliance, responsibilities are allocated across the following key stakeholder roles:

- **Executive Management (CEO & Leadership):**
 - Approve the overall security program, budget allocations for new tools, and compliance strategies.
 - Address the separation of duties risk by restructuring payroll and day-to-day operation authorizations.
- **IT Department (IT Security & Administration):**
 - Deploy and configure the Intrusion Detection System (IDS), firewalls, and antivirus software.
 - Design, test, and maintain disaster recovery plans and data backup procedures.
 - Enforce the principle of Least Privilege by restricting user access permissions to sensitive databases.
 - Implement encryption procedures for customer credit card numbers and sensitive data (PII/SPII).
 - Establish and administer the new password management system.
 - Set up regular monitoring and maintenance schedules for legacy systems.
- **Facilities / Operations Team:**
 - Perform regular checks on physical store assets, including storefront, warehouse locks, and CCTV surveillance systems.
 - Coordinate inspections of fire detection and prevention systems (alarms, sprinklers).
- **Human Resources (HR):**
 - Collaborate with IT to establish and disseminate password security and data protection awareness training.
 - Manage strict onboarding/offboarding checklists to ensure user access is restricted or revoked promptly.
- **All Employees:**
 - Adhere strictly to updated security policies, including password complexity guidelines and clean-desk policies.

Handle client GDPR/PCI DSS protected information securely, maintaining confidentiality at all touchpoints.